Glowy

Rapport de recette

Projet d'équipe · octobre 2026

Version testée : `main` (commit `8a51433`), build de production · **Date** : 26 octobre 2026 **Verdict initial** : recette validée avec réserves (0 bloquante, 3 majeures, 1 moyenne, 3 mineures). **Verdict après corrections** : ✅ **recette validée**. Les 7 anomalies sont corrigées et revérifiées (voir « Statut après corrections »).

Statut après corrections (26 octobre 2026)

Anomalie	Correction	Revérification
QA-01 « absente » avant l'heure	refusé tant que l'heure du rendez-vous n'est pas passée (`409 TOO_EARLY`) ; bouton masqué dans le dashboard	✅ refusé, points inchangés
QA-02 « terminé » avant l'heure	« terminé » après l'heure (ou si déjà commencé), « commencer » au plus tôt 30 min avant	✅ refusé puis accepté après l'heure
QA-03 limites des plans	limites vérifiées côté serveur (1 / 8 / illimité professionnels ; CRM, statistiques, promotions, vues agenda, prévision IA en Pro ; stocks, succursales, mise en avant en Premium), écran « Disponible avec le plan … », rappel 5 jours avant l'échéance puis retour au plan Gratuit	✅ 2e professionnel `PLAN_LIMIT` , fonctions `PLAN_REQUIRED` , page « plan Pro »
QA-04 « bloqué pour vous »	texte honnête : « encore libre : il n'est réservé qu'à la confirmation »	✅
QA-05 identifiant de prestation	la création renvoie `{ id, key }`	✅
QA-06 « Premier disponible »	la confirmation affiche la professionnelle attribuée	✅ « Avec : Amira »
QA-07 darija latine	vocabulaire ajouté (`n9os` , `ta7fifa` , `ghodwa` , `l3chiya` , jours…)	✅ « nheb n9os chaari ghodwa » → 2 créneaux
Constat en cours de correction : prévision d'affluence du dashboard	la carte affichait des données de démo figées ; elle affiche maintenant la vraie prévision des 6 prochains jours (pointe et creux calculés)	✅

Nouvelle campagne complète : 67 / 67 vérifications bout en bout, 96 / 96 pages sans erreur, parcours de réservation sur téléphone réussi, 80 / 80 tests automatisés (dont 5 nouveaux pour ces corrections).

Indicateur	Résultat
Vérifications fonctionnelles bout en bout (13 scénarios, 5 rôles)	**65 / 67 réussies**

Indicateur	Résultat
Pages contrôlées sans erreur (JavaScript, serveur, réseau)	**96 / 96** (48 pages × ordinateur FR et téléphone AR)
Parcours réel dans l'interface (réservation sur téléphone)	**réussi** de bout en bout
Responsive : débordements horizontaux (320 → 1440 px, FR / AR / EN)	**0**
PWA : installabilité (Chrome) · hors connexion	**0 erreur** · **réussi** (mode avion)
Sécurité : accès, CSRF, verrouillage, XSS, énumération de comptes	**tous réussis**
Les 5 IA	**toutes répondent**, avec repli
Temps de réponse (local)	pages 5–22 ms · API ≈ 10 ms
Anomalies	0 bloquante · 3 majeures · 1 moyenne · 3 mineures

1 Périmètre et environnement

- **Application** : site public, espace cliente, dashboard salon (gérant, employé), Super Admin, API REST, PWA.
- **Environnement isolé** : build de production (`next start`, port 3100) sur une base dédiée `beautyhub_qa`, remise à zéro par le seed avant chaque campagne (69 utilisateurs, 12 salons, 1 004 réservations, 38 avis). Les données de démonstration de l'équipe n'ont pas été touchées.
- **Outils** : scénarios automatisés en Node (vraies sessions Auth.js, une par rôle, cookies), Chrome headless piloté par le protocole DevTools (navigation, clics, captures, émulation mobile et hors connexion), contrôles directs en base MongoDB.
- **Rôles joués** : visiteur, cliente (nouveau compte + compte démo), 6 clientes simultanées, gérante, employée, Super Admin.

2 Méthode

1. **Tests fonctionnels bout en bout (API)** : chaque scénario enchaîne des actions réelles et vérifie le statut HTTP, le contenu renvoyé et l'état en base (points, verrous, statuts, journal d'audit).
2. **Cas limites et règles métier** : données invalides, doublons, concurrence, droits croisés entre rôles et entre salons, transitions de statut interdites.
3. **Sécurité** : accès sans session et avec le mauvais rôle, requête d'un autre site (CSRF), force brute, injection de script dans un avis, énumération des comptes.
4. **Contrôle de toutes les pages** : chargement de chaque page pour chaque rôle, relevé des exceptions JavaScript, erreurs console, réponses serveur ≥ 500 et ressources en échec.
5. **Parcours utilisateur réel** : réservation complète par l'interface sur un écran de téléphone (375 px), avec captures.
6. **Responsive, PWA, performances** : audit des débordements, installabilité, mode avion, temps de réponse.

3 Résultats par scénario

Scénario	Vérifications	Résultat
A. Visiteur : santé, recherche, fiche salon	7	✅ 7 / 7
B. Comptes : inscription, connexion, sécurité	10	✅ 10 / 10
C. Réservation (cliente)	9	✅ 9 / 9
D. Gérant : CRUD et cycle du rendez-vous	11	✅ 11 / 11 (avec observation, voir QA-02)
E. Employé	1	✅ 1 / 1
F. Avis et modération	7	✅ 7 / 7
G. Espace client et fidélité	4	✅ 4 / 4
H. Abonnements des salons	5	⚠️ 4 / 5 (QA-03)
I. Super Admin	5	✅ 5 / 5
J. Support	1	✅ 1 / 1
K. Intelligences artificielles	6	✅ 6 / 6 (observation QA-07)
L. Règles métier sensibles	1	❌ 0 / 1 (QA-01)
Total	**67**	**65 / 67**

Détail des vérifications réussies

Comptes et sécurité

- Inscription → 201 ; même e-mail (même en majuscules) → `409 EMAIL_TAKEN` ; données invalides → `400 VALIDATION` détaillé.
- 5 mauvais mots de passe → compte verrouillé (`account_locked`), même avec le bon mot de passe ensuite.
- Mot de passe oublié : lien reçu, nouveau mot de passe accepté, **lien inutilisable une 2e fois** ; adresse inconnue → même réponse et aucun e-mail.
- Sans session → 401 ; cliente sur l'agenda salon ou l'admin → 403 ; pages `/compte`, `/dashboard`, `/admin` → redirection vers la connexion.
- Requête d'écriture venant d'un autre site → **403 (CSRF)**.
- Avis contenant `<script>alert(1)</script>` → texte affiché sans être exécuté (**XSS bloquée**).
- Compte bloqué par le Super Admin → **accès coupé immédiatement**, rétabli au déblocage.

Réservation

- Réservation avec acompte en ligne : 65 DT → acompte 13 DT (20 %, entre 10 et 30 DT).
- **6 clientes réservent le même créneau au même instant → 1 seule acceptée**, 5 refus `SLOT_TAKEN`.
- Créneau passé → `SLOT_IN_PAST` ; report à un autre créneau ; annulation → **tranches libérées** en base ; une autre cliente ne peut pas annuler la réservation.

Dashboard salon (CRUD)

- Prestations : création, lecture, modification, suppression ; durée de 7 min et ancien prix ≤ prix refusés.
- Équipe : employée créée, congé ajouté, modifiée, supprimée.
- Promotions : code créé, appliqué dans un devis (−7 DT), supprimé.
- Stocks : entrées / sorties, **alerte de stock bas**, sortie supérieure au stock refusée (409).
- Caisse : facture numérotée `YAS-2026-00001`, annulation motivée ; un rendez-vous à venir est refusé en caisse.
- Cycle du rendez-vous : en cours → terminé → **points crédités** ; transition impossible → 409.
- **Isolation** : un gérant ne peut pas agir sur un rendez-vous d'un autre salon (403) ; une employée voit l'agenda mais ne peut pas créer de prestation (403).

Avis, fidélité, abonnements, admin, support

- Avis seulement après un rendez-vous terminé (`BOOKING_NOT_COMPLETED`), une seule fois (`ALREADY_REVIEWED`), +15 points ; réponse du gérant, signalement, masquage par le Super Admin ; une cliente ne peut pas modérer (403).
- Profil complet : +20 points **une seule fois** ; favoris ; échange de points refusé si solde insuffisant, code `BH-…` sinon ; notifications.
- Abonnement : déclaration du paiement, 2e demande refusée, refus sans motif refusé, acceptation → **plan Pro 30 jours**, double décision refusée, employée interdite.
- Inscription d'un salon : **invisible tant qu'il n'est pas validé**, puis visible avec le badge « Vérifié » ; journal d'audit alimenté ; export des rapports (CSV) ; annonce à tous.
- Ticket de support : ouverture, réponse, clôture.

Les 5 IA

- Recommandation : salons classés avec leur raison ; affluence en direct ; assistante : « une coupe demain après-midi à La Marsa » → créneaux réels, message incompréhensible → renvoi au formulaire ; analyse d'un avis négatif (sentiment, aspects) ; analyse beauté (score et points d'attention).

Interface, responsive, PWA

- 48 pages × 2 configurations : aucune exception, aucune erreur console, aucune réponse serveur en erreur.
- Parcours réel sur téléphone : connexion → prestation → professionnel → créneau → récapitulatif → « Rendez-vous confirmé » → présent dans « Mes rendez-vous ».
- Aucun débordement de 320 à 1440 px en français, arabe et anglais ; manifest sans erreur d'installabilité ; en mode avion, pages enregistrées et page `/offline` fonctionnelles.

4 Anomalies

Gravité : **Bloquante** (empêche l'usage) · **Majeure** (règle métier fausse, impact sur les données ou l'argent) · **Moyenne** (comportement trompeur) · **Mineure** (confort, cohérence).

QA-01 — Un rendez-vous futur peut être marqué « absente » · Majeure

- **Étapes** : la cliente réserve pour dans 9 jours ; le gérant envoie `PATCH /api/bookings/:id { action: "noShow" }` aujourd'hui.
- **Attendu** : refus tant que l'heure du rendez-vous n'est pas passée.
- **Obtenu** : accepté ; la cliente perd **20 points** (105 → 85) pour un rendez-vous qui n'a pas encore eu lieu.
- **Correction proposée** : dans `setBookingStatus` (`src/modules/booking/application/use-cases.ts`), refuser `noShow` avant `startsAt` (`409 TOO_EARLY`).

QA-02 — Un rendez-vous futur peut être marqué « terminé » · Majeure

- **Étapes** : réservation pour dans 3 jours, puis `start` et `complete` par le gérant le jour même.
- **Obtenu** : accepté ; **points crédités** (0 → 60) et **avis possible** avant le rendez-vous. Incohérent avec la caisse, qui refuse déjà d'encaisser un rendez-vous à venir (`FUTURE_BOOKING`).
- **Correction proposée** : `start` autorisé au plus tôt quelques minutes avant `startsAt`, `complete` seulement après `startsAt` ; même règle que la caisse.

QA-03 — Les limites des plans ne sont pas appliquées · Majeure (métier)

- **Constat** : la page `/pro` annonce « 1 employé » pour le plan Gratuit, mais le salon Gratuit « Nail Studio Menzah » a 2 employés actifs, et un salon Gratuit accède au CRM, aux statistiques, aux promotions, aux stocks et aux succursales.
- **Constat lié** : à l'échéance des 30 jours, le plan reste « Pro » en base (seul l'affichage passe à 0 jour restant).
- **Correction proposée** : limites par plan vérifiées côté serveur (nombre d'employés, fonctions Pro / Premium), retour automatique au plan Gratuit à l'échéance par la tâche planifiée, avec rappel au gérant.

QA-04 — « Créneau bloqué pour vous pendant 10 min » sans blocage réel · Moyenne

- **Étapes** : au récapitulatif du tunnel, le compte à rebours affiche « Créneau mercredi 28 octobre à 09:00 bloqué pour vous pendant 9:58 ».
- **Obtenu** : aucun verrou n'est posé côté serveur avant la confirmation ; une autre cliente peut prendre ce créneau pendant le compte à rebours (la confirmation renvoie alors `SLOT_TAKEN`, ce qui est géré, mais la promesse affichée est fausse).
- **Correction proposée** : soit poser un verrou temporaire de 10 min (collection `SlotLock` avec expiration), soit remplacer le texte par « Confirmez rapidement : ce créneau n'est pas encore réservé ».

QA-05 — Création de prestation : identifiant non renvoyé · Mineure

- `POST /api/dashboard/services` renvoie `{ key }`, alors que `PATCH` et `DELETE /api/dashboard/services/:id` attendent l'`id`. Un client de l'API doit relire la liste pour modifier ce qu'il vient de créer. Renvoyer `{ id, key }`.

QA-06 — Confirmation : « Avec : Premier disponible » · Mineure

- Après une réservation « peu importe », l'écran de confirmation affiche « Premier disponible » au lieu du nom de la professionnelle réellement attribuée (connu après la réservation).

QA-07 — Assistante : phrase courante en darija non comprise · Mineure

- « nheb n9os chaari ghodwa » (je veux couper mes cheveux demain) → réponse de repli (renvoi au formulaire) au lieu de créneaux. Le repli fonctionne, mais la compréhension de la darija écrite en lettres latines et chiffres (`9`, `3`, `7`) est à enrichir (`src/modules/assistant/domain/nlu.ts`).

Observations (comportement attendu)

- File d'attente virtuelle fermée en dehors des horaires du salon (`QUEUE_CLOSED`) : normal, testée hors horaires.

5 Points forts constatés

- **Intégrité des réservations** : aucune double réservation possible, même sous concurrence (verrou en base).
- **Sécurité solide** : contrôle d'accès à chaque route, CSRF, verrouillage après 5 échecs, liens à usage unique, pas d'énumération des comptes, XSS neutralisée, isolation entre salons.
- **Messages d'erreur précis et stables** (`SLOT_TAKEN`, `EMAIL_TAKEN`, `ALREADY_REVIEWED`…), traduits à l'écran.
- **Stabilité** : 96 chargements de pages sans aucune erreur, en deux langues et deux tailles d'écran.
- **Mobile first** réel : parcours complet fluide sur téléphone, aucun débordement de 320 à 1440 px.

6 Non couvert par cette recette

- Envoi réel d'e-mails (SMTP non configuré : e-mails simulés et vérifiés dans la boîte d'envoi).
- Notifications push et installation sur de vrais téléphones (iPhone, Android) : vérifiées dans Chrome uniquement.
- Paiement en ligne réel (mode test).
- Charge (centaines d'utilisateurs simultanés) et performances sur un hébergement réel.
- Accessibilité avec lecteur d'écran (seuls les libellés des boutons et les cibles tactiles de 44 px ont été vérifiés).

7 Recommandations, par priorité

1. **QA-01 et QA-02** : bloquer `noShow`, `start` et `complete` avant l'heure du rendez-vous (correction courte, fort impact sur les points).
2. **QA-03** : appliquer les limites des plans et l'échéance (sinon les plans payants n'apportent rien).
3. **QA-04** : rendre le texte du compte à rebours honnête, ou poser un vrai verrou temporaire.
4. **QA-05 à QA-07** : corrections de confort.
5. Ajouter ces scénarios aux tests automatisés (`npm test`) pour éviter toute régression.